

M 304: MobSF Static Analysis (25 pts extra)

What You Need for This Project

- A Linux virtual machine

Purpose

To practice using Mobile Security Framework (MobSF), an automated, all-in-one mobile application (Android/iOS/Windows) pen-testing, malware analysis and security assessment framework capable of performing static and dynamic analysis.

Finding your Linux Server's IP Address

On Linux, execute this command:

```
ip a
```

Make a note of your Linux server's IP address. You'll need it later.

Installing Docker

MobSF runs as a Docker container, which is like a smaller, faster virtual machine.

To run Docker containers, you must first install docker.

On Linux, execute these commands, one at a time. Notice that some of these commands continue onto a second line.

```
sudo apt update

sudo apt install apt-transport-https ca-certificates curl gnupg git

curl -fsSL https://download.docker.com/linux/debian/gpg \
| sudo gpg --dearmor -o /usr/share/keyrings/docker.gpg

echo "deb [arch=$(dpkg --print-architecture) signed-by=/usr/share/keyrings/docker.gpg] https://download.docker.com/linux/debian bookworm stable" \
| sudo tee /etc/apt/sources.list.d/docker.list > /dev/null

sudo apt update

sudo apt install docker-ce docker-ce-cli containerd.io docker-buildx-plugin

sudo systemctl is-active docker
```

Docker is active, as shown below.

A terminal window with a dark background and light text. The window title bar shows 'sambowne — debian@debian: ~ — ssh debian@172.16.123.139 — 80x11'. The terminal output shows the installation of Docker components: 'Setting up docker-buildx-plugin (0.12.1-1~debian.12~bookworm) ...', 'Setting up containerd.io (1.6.28-1) ...', 'Setting up docker-ce-cli (5:25.0.3-1~debian.12~bookworm) ...', 'Setting up docker-ce-rootless-extras (5:25.0.3-1~debian.12~bookworm) ...', 'Setting up docker-ce (5:25.0.3-1~debian.12~bookworm) ...', 'Installing new version of config file /etc/init.d/docker ...', and 'Processing triggers for man-db (2.11.2-2) ...'. The user then runs 'sudo systemctl is-active docker' and the output is 'active'. The prompt 'debian@debian:~\$' is visible at the bottom.

```
sambowne — debian@debian: ~ — ssh debian@172.16.123.139 — 80x11
.7-1~debian.12~bookworm) ...
Setting up docker-buildx-plugin (0.12.1-1~debian.12~bookworm) ...
Setting up containerd.io (1.6.28-1) ...
Setting up docker-ce-cli (5:25.0.3-1~debian.12~bookworm) ...
Setting up docker-ce-rootless-extras (5:25.0.3-1~debian.12~bookworm) ...
Setting up docker-ce (5:25.0.3-1~debian.12~bookworm) ...
Installing new version of config file /etc/init.d/docker ...
Processing triggers for man-db (2.11.2-2) ...
debian@debian:~$ sudo systemctl is-active docker
active
debian@debian:~$
```

Installing MobSF

On Linux, in a Terminal, execute these commands, one at a time.

The pull command downloads a lot of data, and may take a long time if your network is slow.

```
sudo docker pull opensecurity/mobile-security-framework-mobsf:latest
```

```
sudo docker run -it --rm -p 8000:8000 opensecurity/mobile-security-framework-mobsf:latest
```

MobSF starts listening on port 8000, as shown below.

```
sambowne — debian@debian: ~ — ssh debian@172.16.123.139 — 94x25

[MOBSF]

[INFO] 15/Feb/2024 22:36:25 — Author: Ajin Abraham | opensecurity.in
[INFO] 15/Feb/2024 22:36:25 — Mobile Security Framework v3.9.4 Beta
REST API Key: 7ea852dcafe8734b7c2b2be4229dce3e297b48d796cbe0eea2201f26fc3bcb5d
[INFO] 15/Feb/2024 22:36:25 — OS Environment: Linux (ubuntu 22.04 Jammy Jellyfish) Linux-6.1.0
-15-amd64-x86_64-with-glibc2.35
[INFO] 15/Feb/2024 22:36:25 — MobSF Basic Environment Check
[INFO] 15/Feb/2024 22:36:25 — Checking for Update.
Operations to perform:
  Apply all migrations: StaticAnalyzer, auth, contenttypes, sessions
Running migrations:
  No migrations to apply.
[INFO] 15/Feb/2024 22:36:25 — No updates available.
[2024-02-15 22:36:26 +0000] [1] [INFO] Starting gunicorn 21.2.0
[2024-02-15 22:36:26 +0000] [1] [INFO] Listening at: http://0.0.0.0:8000 (1)
[2024-02-15 22:36:26 +0000] [1] [INFO] Using worker: gthread
[2024-02-15 22:36:26 +0000] [91] [INFO] Booting worker with pid: 91
[2024-02-15 22:36:49 +0000] [1] [INFO] Handling signal: winch
[2024-02-15 22:36:49 +0000] [1] [INFO] Handling signal: winch
```

Viewing the MobSF Web Page

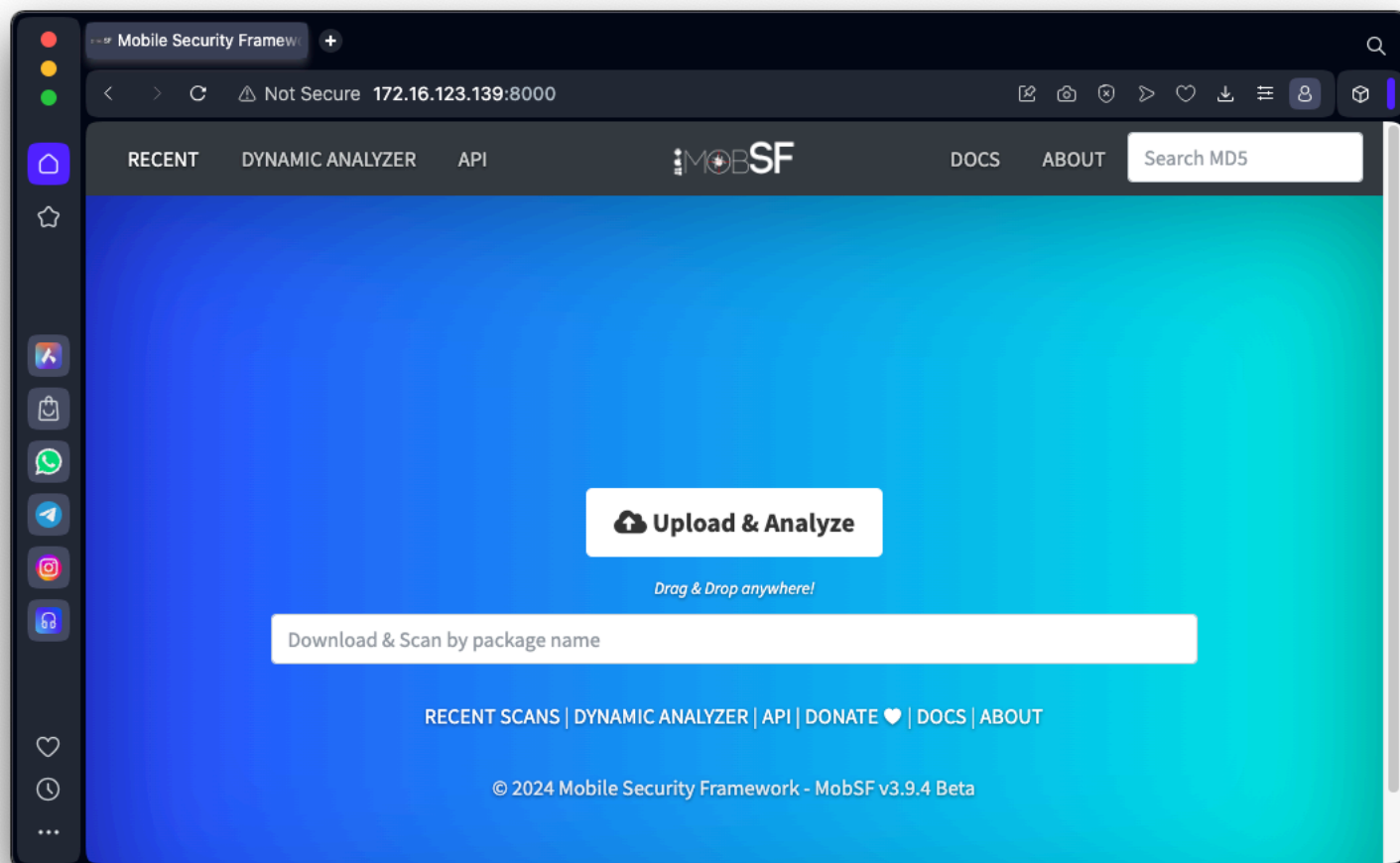
In a Web browser, open this URL, replacing the IP address with the correct IP address of your Linux server:

`http://172.16.123.139:8000`

You see the MobSF Web page.

Log in with a username and password of **mobsf**

You see the "Upload & Analyze" page, as shown below.



Analyzing a Vulnerable App

Download this APK file:

[genie.apk](#)

Drag and drop the **genie.apk** file onto the MobSF Web page.

Wait while the MobSF analyzes the app.

When it finishes, you see a pretty display of the results, as shown below.

Static Analysis

Not Secure 172.16.123.139:8000/static_analyzer/dba8656f3c69338a38cf821d34cd25b4/

MobSF

RECENT SCANS STATIC ANALYZER DYNAMIC ANALYZER API DONATE DOCS ABOUT Search MD5

Static Analyzer

Information Scan Options Signer Certificate Permissions Android API Browsable Activities Security Analysis Malware Analysis Reconnaissance Components PDF Report Print Report Start Dynamic Analysis

APP SCORES

FILE INFORMATION

APP INFORMATION

Security Score 38/100 Trackers Detection 3/432 MobSF Scorecard

File Name genie.apk Size 37.81MB MD5 dba8656f3c69338a38cf821d34cd25b4 SHA1 52e80323d65f489707af3bbc76c33c782ac7fc47 SHA256 bf316e6c25fed4dec27e46b11ca1dead1a995deded5fe4d7c35cfc3393cc96a

App Name Harvard Health Info Package Name com.geniemd.geniemd.harvard Main Activity com.geniemd.geniemd.banglalink.OemMain Target SDK 19 Min SDK 14 Max SDK Android Version Name 5.9.9.50 Android Version Code 559050

196 ACTIVITIES View

3 SERVICES View

3 RECEIVERS View

0 PROVIDERS View

Exported Activities 5

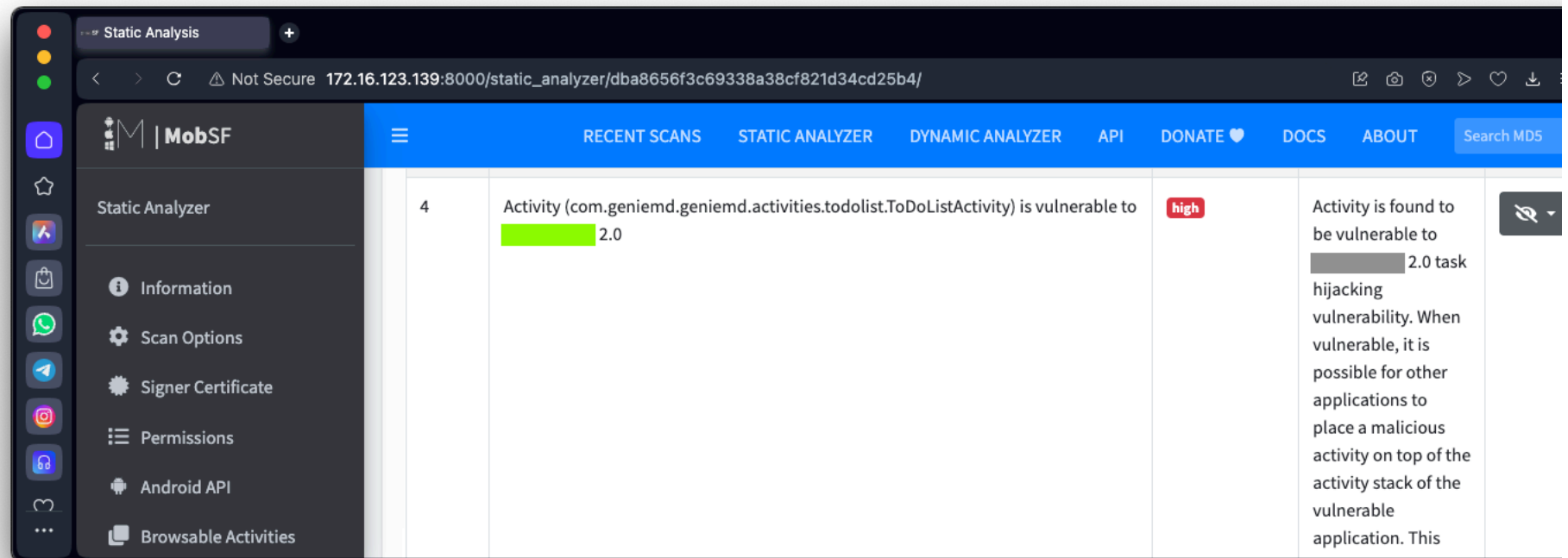
Exported Services 1

Exported Receivers 2

Exported Providers 0

SCAN OPTIONS DECOMPILED CODE

Scroll down to the MANIFEST ANALYSIS section as shown below.



M 304.2: MANIFEST ANALYSIS (5 pts)

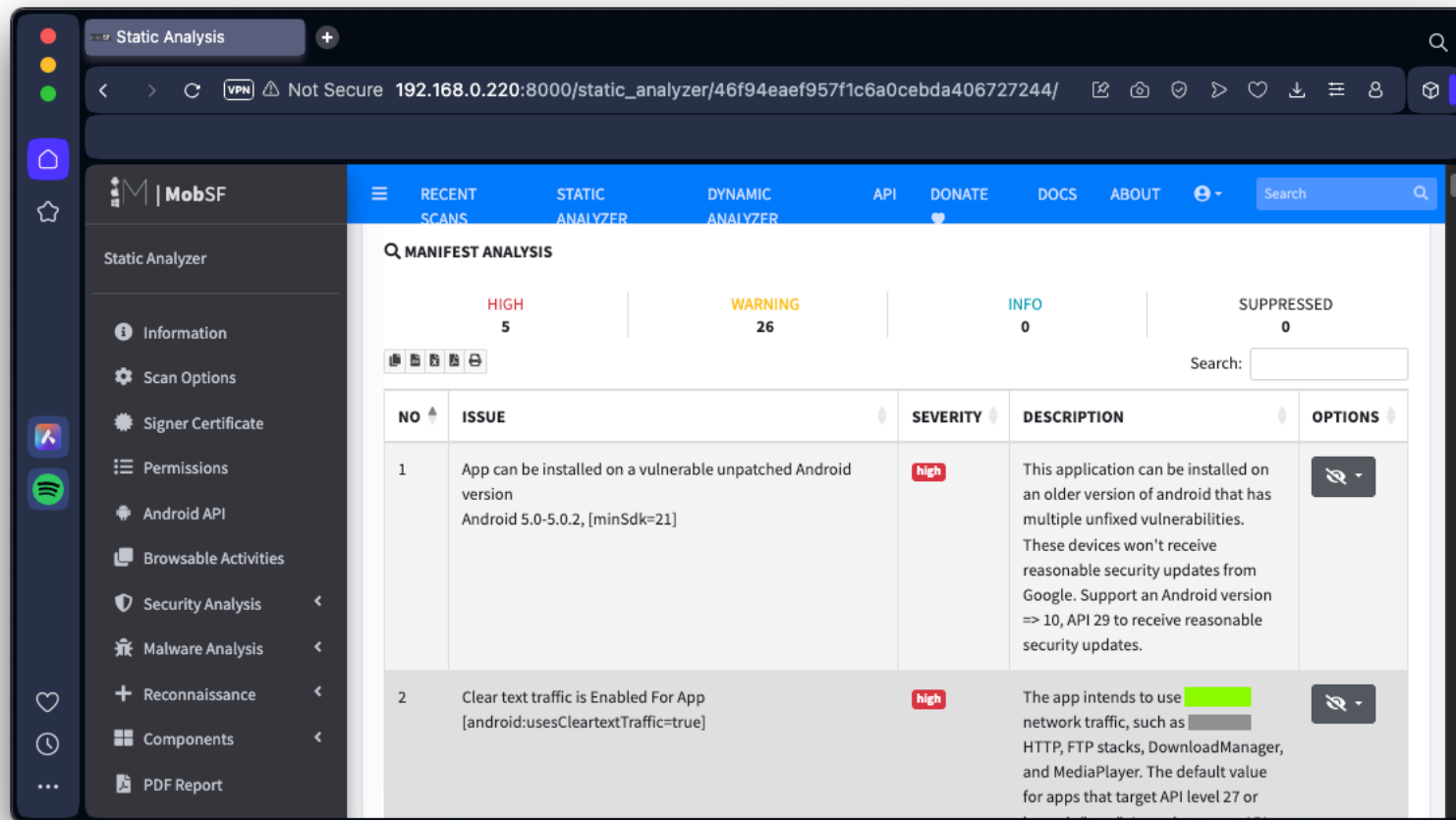
At the top left, click the **MobSF** logo.

Analyze this app, which the [Chinese government](#) uses to scan phones of citizens:

[National Anti Fraud Center.apk](#)

The app is larger than the "genie" app, so the analysis will take longer.

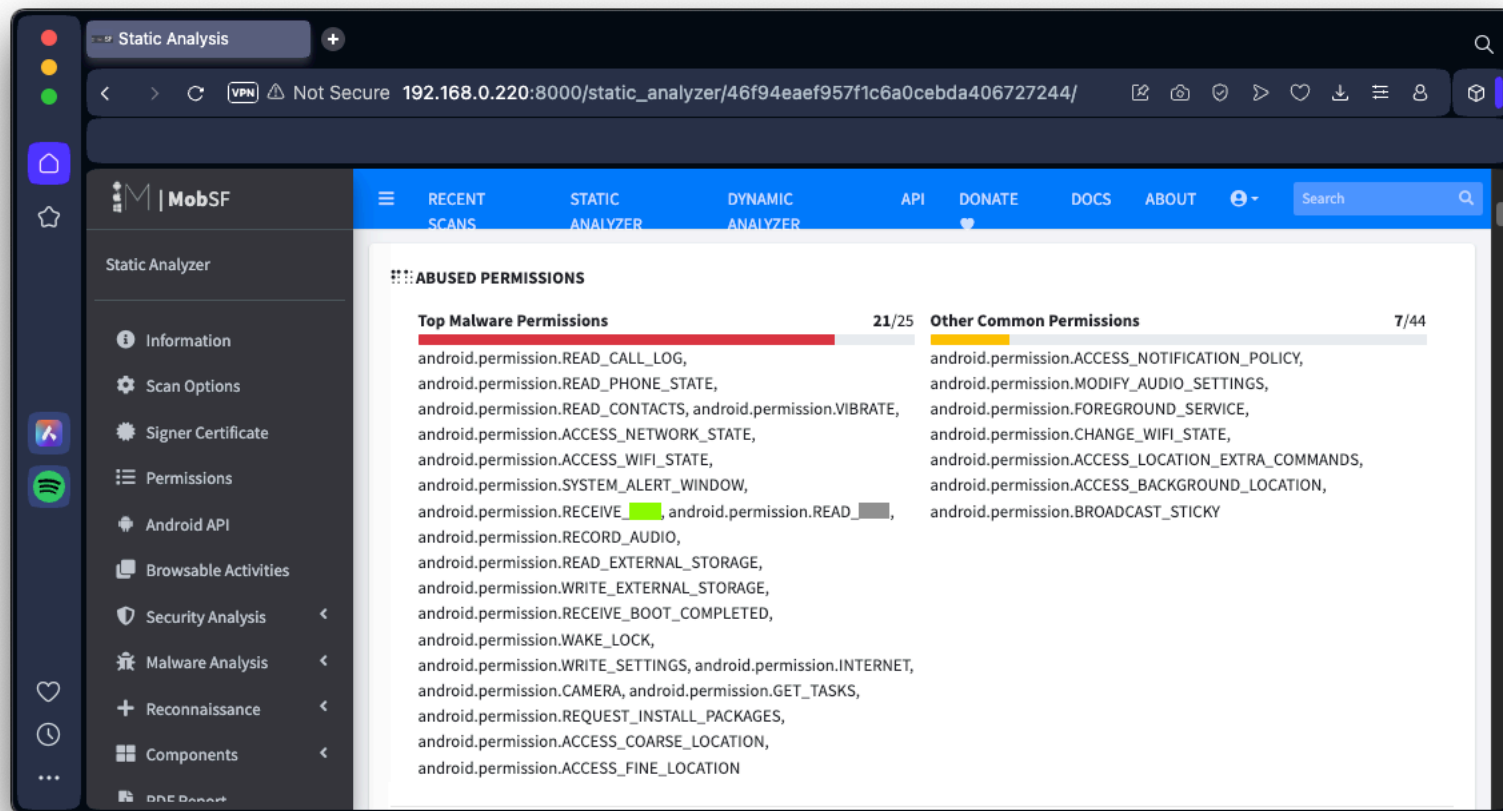
In the the MANIFEST ANALYSIS section, find the text covered by a green box in the image below. That's the flag.



M 304.3: ABUSED PERMISSIONS (5 pts)

For the National_Anti_Fraud_Center.apk, examine the ABUSED PERMISSIONS.

Find the text covered by a green box in the image below. That's the flag.



M 304.4: Registration Code (5 pts)

Analyze this app:

<https://www.bowneconsultingcontent.com/pub/Attack/proj/A31.2.apk>

Near the bottom of the page, in the Strings section, expand the container to see all the strings.

find the registration code, covered by a green box in the image below. That's the flag.



References

[Mobile Security Framework \(MobSF\)](#)
[MobSF Documentation](#)
[Dynamic Analysis Not Supported in Docker](#)

Posted 2-15-24

Login section added 6-10-25

Images updated 11-5-25